정보보안학 기초 Part02

챕터별 상세 요약 정리 — 제2권

방어 인프라부터 보안 거버넌스까지 · 11~17장 종합 정리

목차

11장. 침입탐지시스템과 보안관제

12장. 방화벽과 네트워크 경계 보안

13장. 물리적 보안과 시설 보호

14장. 생체인식 기술과 인증 시스템

15장. 접근제어 모델과 권한 관리

16장. 보안 정책과 거버넌스 체계

17장. 위험 분석과 보안 투자 결정

11 장. 침입탐지시스템과 보안관제

방화벽이 나쁜 사람이 들어오지 못하도록 문을 잠그는 역할이라면, 침입탐지시스템(IDS)은 이미 들어온 침입자나 내부에서 일어나는 수상한 활동을 발견하는 역할입니다. 즉 예방이 아닌 탐지에 초점을 맞춥니다. 2013년 한국 주요 방송사·은행이 동시에 마비된 사이버 테러에서 해커들이 몇 달간 조용히 침투했으나 기존 시스템이 이를 감지하지 못한 사건이, 침입 탐지·대응 시스템의 필요성을 일깨웠습니다.

IDS 의 두 가지 유형 (설치 위치별)

- **NIDS (네트워크 기반)** — 네트워크를 흐르는 모든 데이터 패킷을 실시간 감시. 교통경찰이 도로의 모든 차량을 관찰하듯 주요 지점에 센서를 설치해 통신 내용을 복사·분석합니다. 고속 환경에서는 초당 수백만 패킷을 실시간 처리할 강력한 컴퓨팅 성능이 필요합니다.
- **HIDS (호스트 기반)** — 개별 컴퓨터·서버에 설치되어 파일 접근 기록, 로그인 시도, 프로그램 실행, 시스템 설정 변경 등을 감시. 네트워크로 전송되지 않는 내부 활동과 암호화 통신도 복호화 상태로 확인할 수 있으나, 시스템마다 개별 설치·관리해야 해 대규모 환경에서 부담이 큽니다.

탐지 방법의 두 가지

- **시그니처 기반 탐지** — 알려진 공격 패턴을 DB 에 저장해 두고 일치하는 트래픽·행동을 탐지(위조지폐 특징을 미리 아는 것에 비유). 정확도가 높고 오탐율이 낮지만, 새로운 공격이나 변형 공격에는 대응이 어렵습니다.
- **이상 징후 기반 탐지** — 정상 패턴을 학습해 기준선(baseline)을 설정하고, 크게 벗어나는 활동을 이상 징후로 판단(머신러닝 활용). 새로운 공격도 탐지 가능하지만, 정상이지만 평소와 다른 활동을 오인해 오탐율이 높은 단점이 있습니다.

실제 환경에서는 두 방법을 결합한 하이브리드 접근을 많이 사용합니다. 알려진 공격은 시그니처로 정확히 차단하고, 새로운 위협은 이상 징후 탐지로 잡아냅니다.

허니팟과 허니넷

- **허니팟** — 함정을 설치해 침입자를 유인하는 방법. 의도적으로 취약하게 설정한 가짜 시스템으로, 정상 사용자는 접근할 이유가 없으므로 여기 들어오는 활동은 거의 100% 악의적인 것으로 간주할 수 있어 오탐 문제를 해결하고 공격자의 행동 패턴을 연구할 수 있습니다.
  2002 년 랜스 스피츠너가 이를 활용해 해커의 침입 과정을 상세히 관찰했습니다.

- **허니넷** — 여러 허니팟을 연결해 가상 네트워크 환경을 구축한 것. 더 현실적인 공격 시나리오를 관찰할 수 있으나, 공격자가 이를 발판으로 다른 시스템을 공격하지 못하도록 격리하는 것이 중요합니다.

보안관제센터(SOC)

모든 침입탐지 기술이 모여 작동하는 곳으로, 군사작전 지휘본부나 119상황실 같은 역할을 합니다. 24시간 365일 보안 전문가가 실시간으로 사이버 위협을 감시·분석합니다. 2014년 소니 픽처스 해킹 당시 며칠 전부터 이상 징후가 감지됐으나 심각한 위협으로 인식하지 못해 대규모 유출을 막지 못했는데, 이는 경보를 받는 것을 넘어 정확히 분석하고 신속히 대응하는 능력의 중요성을 보여줍니다.

- **3 단계 계층 구조** — 1 차 분석가(실시간 경보 초기 검토, 거짓 경보 필터링) → 2 차 분석가(사건 상세 조사, 규모·영향도 평가, 대응 방안 수립) → 3 차 전문가(가장 복잡·심각한 사고에 대한 심층 분석 및 정책·시스템 개선안 제시).

SIEM 시스템

Security Information and Event Management의 약자로, 조직 내 모든 보안 장비(방화벽·IDS·안티바이러스·서버·네트워크 장비)에서 발생하는 로그·이벤트를 하나의 중앙집중식 플랫폼으로 수집·통합 분석합니다. 여러 CCTV 화면을 하나의 통합 모니터에서 보는 것과 같습니다.

- **상관관계 분석** — 각각은 별것 아닌 이벤트라도 종합하면 위협이 되는 패턴을 자동 분석. 예: 한 사용자가 평소보다 많은 파일에 접근 + 대용량 외부 전송 발생 + 야간 로그인 시도가 겹치면 내부자 정보 유출 시도일 가능성이 높습니다.
- **한계와 발전** — 실시간 로그 처리를 위한 강력한 인프라와, 서로 다른 형식의 로그를 표준화·통합하는 작업, 결과를 해석할 숙련된 전문가가 필요합니다. 최근에는 AI·머신러닝을 접목해 사후 대응에서 사전 예측·예방의 능동적 역할로 진화하고 있습니다.

> **핵심 요점** IDS·SOC·SIEM은 '이미 침입했거나 침입 중인 위협'을 찾아내는 방어의 눈과 두뇌입니다. 탐지에서 끝나지 않고 신속·정확한 분석과 대응이 핵심입니다.

12 장. 방화벽과 네트워크 경계 보안

방화벽은 외부의 악의적 공격이 네트워크 안으로 퍼지지 않도록 막아주는 디지털 문지기입니다. 이름은 건물에서 불이 번지지 않도록 설치하는 방화벽에서 따왔습니다. 1980년대 후반 인터넷 보급과 함께 필요성이 대두되어 1990년대 초 최초의 상용 방화벽이 등장했습니다.

방화벽의 발전 단계

- **패킷 필터링 방화벽** — 초기 방식. 각 패킷의 헤더 정보(발신·수신 주소, 프로그램 정보)만 보고 통과/차단을 결정. 특정 웹사이트 IP 를 차단 목록에 넣으면 그 주소로 향하는 패킷이 모두 차단됩니다. 각 패킷을 독립적으로 판단해 전체적인 통신 흐름(맥락)을 파악하지 못하는 한계가 있었습니다.
- **상태 추적 방화벽 (Stateful Firewall)** — 개별 패킷이 아니라 연결의 전체 맥락(State=연결 상태)을 파악. 사용자가 웹사이트에 보낸 연결 요청을 기록해 두었다가, 서버 응답이 오면 앞서 기록한 요청과 매칭해 정상 응답인지 확인합니다. TCP 연결 하이재킹·세션 스푸핑 같은 공격을 효과적으로 차단해 1990 년대 중반부터 네트워크 보안의 핵심 기술로 자리잡았습니다.
- **차세대 방화벽 (NGFW)** — 포트·프로토콜 기반 제어를 넘어 애플리케이션 자체를 식별·제어. 같은 웹 트래픽이라도 페이스북인지, 유튜브인지, 업무용 클라우드인지 구분할 수 있습니다. 침입 방지 시스템(IPS)을 통합하고, IP 주소가 아닌 실제 사용자 계정 기준으로 접근 정책을 적용합니다.

네트워크 분할 — DMZ

방화벽만으로는 충분하지 않아 등장한 개념이 DMZ(Demilitarized Zone, 비무장지대)입니다. 남북한 사이 완충지대처럼 외부 인터넷과 내부 네트워크 사이에 완충지대를 만드는 것입니다.

- **DMZ 의 구성** — 웹 서버·메일 서버·FTP 서버 등 외부에서 접근해야 하는 서버를 배치. DMZ 서버가 해킹당하더라도 내부 네트워크까지 침투하기 어렵게 만듭니다. 핵심은 네트워크 분할로, 하나의 큰 네트워크를 여러 작은 네트워크로 나누고 각각 다른 보안 정책으로 관리합니다.

최신 동향

- **가상 방화벽** — 물리 하드웨어가 아닌 소프트웨어로 구현되어 클라우드 환경에서 동작. 필요에 따라 빠르게 생성·제거하고 트래픽 변화에 맞춰 성능을 유연하게 조절합니다.
- **마이크로 세그멘테이션** — 네트워크를 크게 몇 구간으로 나누던 방식에서 나아가, 워크로드·애플리케이션 단위로 매우 세밀하게 분할. 한 시스템이 침해당해도 다른 시스템으로의 확산을 최소화합니다(코로나 19 사회적 거리두기로 감염 확산을 막는 것과 유사).

핵심 요점 방화벽은 패킷 필터링 → 상태 추적 → 차세대(애플리케이션 인식)로 진화해 왔으며, DMZ·세그멘테이션과 결합해 '경계에서 침입을 막고 확산을 차단'하는 역할을 합니다.

13 장. 물리적 보안과 시설 보호

아무리 강력한 암호화와 첨단 네트워크 보안 장비를 갖춰도 누군가 서버실에 직접 들어가 하드디스크를 빼간다면 모든 노력이 물거품이 됩니다. 물리적 보안은 정보보안의 가장 기본이 되는 첫 번째 방어선으로, 건물·시설·장비·사람을 물리적 위협으로부터 보호합니다. 2013년 에드워드 스노든은 복잡한 해킹이 아니라 단순히 USB 드라이브를 사무실로 가져가 파일을 복사했는데, 이는 물리적 접근 통제의 중요성을 극명하게 보여줍니다.

> **핵심 요점** 보안 전문가들은 «물리적 접근권을 얻으면 게임은 끝난다»고 말합니다. 서버에 직접 접근하면 하드웨어 조작, 키로거 설치, 시스템 반출까지 가능하기 때문입니다.

출입 통제 시스템

- **카드키 시스템** — 자기 띠나 RFID 칩이 내장되어 특정 방 문만 열 수 있고, 체크아웃 시간이 지나면 자동 비활성화됩니다. 기업 시스템은 직원마다 다른 접근 권한과 시간대별 제한을 둘 수 있습니다(일반 직원 평일 9~18 시, 보안팀 24 시간).
- **듀얼 퍼슨 컨트롤** — 두 사람이 동시에 인증해야 들어갈 수 있는 공간. 은행 금고나 핵시설 같은 극도로 민감한 장소에 사용됩니다.
- **다단계 인증** — ①무엇을 가지고 있는가(카드키·토큰) ②무엇을 알고 있는가(비밀번호·PIN) ③당신이 누구인가(지문·홍채 등 생체정보). 두 개 이상 조합하면 보안성이 급격히 높아집니다.
- **테일게이팅 방어** — 권한자 뒤를 따라 몰래 들어가는 공격. 이를 막기 위해 안티 패스백 시스템(건물에 들어간 카드로는 다시 들어갈 수 없고, 나간 기록이 있어야 재입장 가능)을 도입합니다.

감시 시스템 — CCTV

1942년 독일 V-2 로켓 발사 모니터링을 위해 최초 설치된 이후 보안 필수 도구가 되었습니다. 현대 CCTV는 AI 영상 분석으로 금지 구역 접근·비정상적 장시간 체류 등을 자동 감지해 경보를 발생시킵니다. 2001년 9.11 테러 이후 얼굴 인식 CCTV가 급속히 확산되었으나, 개인정보보호·감시 사회에 대한 우려도 함께 커져 유럽 일부 국가는 공공장소 얼굴 인식 사용을 제한하는 법안을 검토하고 있습니다.

데이터센터의 환경 관리

- **냉각·온습도** — 서버는 24 시간 가동되며 막대한 열을 발생시켜 정교한 냉각이 필요. 대부분의 데이터센터는 온도 18~27 도, 습도 45~65%를 유지합니다(너무 건조하면 정전기, 너무 습하면 부식·합선 위험).

- **전력 공급 (UPS)** — 무정전 전원 공급 장치(UPS)가 순간 정전을 처리하고, 이후 디젤 발전기가 장시간 전력을 공급. 일부는 별도 전력망에 연결되어 있어 한쪽에 문제가 생겨도 전환할 수 있습니다.
- **화재 진압** — 물 스프링클러는 전자 장비를 손상시키므로 사용할 수 없어, 산소 농도를 낮춰 화재를 억제하는 가스 기반 진압 시스템을 사용. 작동 시 즉시 대피해야 하므로 명확한 대피 절차와 경보가 필요합니다.

소셜 엔지니어링과 인적 보안

소셜 엔지니어링은 기술적 해킹보다 인간의 심리를 이용하는 공격입니다. 공격자는 직원·수리 기사·배달원으로 위장해 건물에 침입합니다(2008년 은행에 피자 배달원으로 위장 침입, 점심시간에 자연스럽게 들어가 악성 프로그램 설치). 방어의 핵심은 직원 교육으로, 방문자 신분 확인·동행자 배정, 중요 구역에 혼자 두지 않기, «친절하되 경계심을 잃지 말라»는 원칙 교육이 중요합니다.

재해 복구 계획

물리적 보안의 마지막 방어선. 2001년 9.11 테러 당시 백업 시설을 갖춘 금융회사들은 빠르게 업무를 재개할 수 있었습니다. 효과적인 재해 복구 계획은 중요 데이터를 지리적으로 떨어진 곳에 백업하고(같은 건물·도시는 동일 재해 영향을 받음), 정기적인 복구 테스트로 백업이 실제 사용 가능한지 확인하는 것입니다.

> **핵심 요점** 물리적 보안은 정보보안의 토대입니다. 출입 통제·감시·환경 관리·인적 보안이 조화롭게 작동해야 하며, 결국 이를 운영하는 사람의 보안 의식이 가장 중요한 요소입니다.

14 장. 생체인식 기술과 인증 시스템

생체인식은 우리 몸에 새겨진 고유한 특징(지문·홍채·음성·얼굴 등)을 디지털로 변환해 개인을 식별하는 방법입니다. 비밀번호나 카드와 달리 잃어버릴 수 없고 도난 위험도 훨씬 적은데, 그것이 바로 '당신 자신'이기 때문입니다.

생체적 특징 vs 행동적 특징

- **생체적 특징** — 태어날 때부터 새겨진 물리적 특성(지문·홍채·얼굴·손바닥 정맥). 일반적으로 더 안정적이고 변하지 않습니다.
- **행동적 특징** — 행동 방식에서 나타나는 고유 패턴(음성 톤·속도, 서명 방식, 걸음걸이, 타이핑 리듬). 감정·건강 상태에 따라 변할 수 있어 상대적으로 불안정합니다.

주요 생체인식 기술

- **지문 인식** — 1880 년대 프랜시스 골턴이 고유성을 과학적으로 증명, 1901 년 스코틀랜드 야드에서 범죄 수사에 최초 활용. 미국 FBI 가 1975 년 개발한 AFIS 는 수백만 지문 DB 에서 일치 검색 시간을 몇 주에서 몇 분으로 단축했습니다. 정확도는 99.8% 이상이나, 손가락 상처·건조·습기·노화 시 인식률이 떨어질 수 있습니다.
- **홍채 인식** — 지문보다 높은 정확도. 홍채에는 무려 266 개의 독특한 특징점이 존재합니다(지문은 약 40 개). 생후 18 개월경 완성되어 평생 변하지 않으며, 일란성 쌍둥이도 서로 다른 패턴을 가집니다. 적외선 카메라로 촬영해 512 바이트 디지털 코드로 변환하며, 오인식률이 120 만분의 1 로 매우 낮아 공항·군사시설 같은 고보안 영역에서 주로 사용됩니다.
- **얼굴 인식** — 일상에서 가장 자주 접하는 방식(스마트폰 잠금 해제, 공항 출입국 관리, CCTV 실시간 추적). 두 눈 사이 거리, 코의 높이·폭, 입술 두께, 턱 모양 등 기하학적 특징을 분석하며, 딥러닝으로 정확도가 크게 향상되었습니다. 조명·각도·표정·안경·마스크에 영향을 받는 한계가 있어, 코로나 19 이후 마스크 착용 상태에서도 인식 가능한 기술 개발이 활발합니다.
- **음성 인식** — 성대 길이·두께, 목구멍·입술 모양이 달라 각자 독특한 음성 패턴을 가집니다. 주파수 특성, 포먼트 구조, 말하는 속도·리듬을 분석하며 은행 전화 상담·스마트 스피커 인증에 활용. 감기·감정 상태·주변 소음에 인식률이 떨어질 수 있고, 녹음 재생 스푸핑에 취약해 생존성 검증 기능이 필요합니다.
- **서명 인식** — 모양뿐 아니라 펜 압력, 쓰는 속도, 펜을 들어올리는 시점·횟수, 글자 쓰는 순서 등 동적 특성을 종합 분석. 정적인 이미지 비교보다 훨씬 높은 보안성을 제공해 금융기관의 고액 거래 승인·중요 계약서 서명에 활용됩니다.

생체정보 템플릿의 보안

생체정보는 일단 유출되면 변경할 수 없다는 치명적 특성이 있습니다. 비밀번호는 재설정할 수 있지만, 지문·홍채 정보가 해킹당하면 평생 그 생체정보를 사용할 수 없게 됩니다. 따라서 생체정보 템플릿은 원본으로 복원이 불가능한 형태로 암호화해 저장해야 하고, 템플릿 자체도 해시 함수나 양방향 변환으로 추가 보호 계층을 적용하는 것이 일반적입니다.

다중 생체인식과 미래

- **다중 생체인식** — 여러 생체정보를 조합(지문+홍채, 얼굴+음성)해 정확성·신뢰성을 높이고 스푸핑 저항성을 강화. 다만 복잡성·비용이 증가하고 편의성이 떨어질 수 있어, 보안 요구 수준과 사용 환경을 고려해 선택합니다.
- **발전 방향** — 정맥 패턴 인식, 심장박동 패턴 분석, 뇌파 인식 등이 연구되고 있으며 AI 와 결합해 더 똑똑하고 안전한 인증으로 진화 중입니다. 편리함·보안성과 함께 개인정보보호·프라이버시 침해 우려도 중요한 과제입니다.

> **핵심 요점** 생체인식은 '잃어버릴 수 없는 열쇠'라는 강점이 있지만, 유출 시 되돌릴 수 없다는 점 때문에 템플릿 보호와 프라이버시가 핵심 과제입니다.

15 장. 접근제어 모델과 권한 관리

접근제어란 누가 어떤 자원에 언제 어떻게 접근할 수 있는지 결정하고 통제하는 체계입니다. 정보시스템에서 사용자가 파일·프로그램·데이터베이스에 접근할 때 적절한 권한을 가졌는지 확인하고 허용 여부를 결정합니다.

접근제어의 3 가지 기본 요소

- **주체(Subject)** — 시스템에 접근하려는 사용자나 프로그램.
- **객체(Object)** — 접근 대상이 되는 파일·데이터베이스·프로그램 등의 자원.
- **접근 권한** — 읽기·쓰기·실행·삭제 등 구체적인 작업 유형. 적절한 권한을 가진 주체만이 특정 객체에 원하는 작업을 수행할 수 있습니다.

접근제어 모델의 발전

- **DAC (임의적 접근제어)** — 자원 소유자가 다른 사용자에게 권한을 자유롭게 부여·회수. 자기 휴대폰 사진을 친구에게 보여줄지 결정하는 것과 같습니다(윈도우 파일 공유 설정이 대표 예). 직관적·유연하지만 사용자 실수·악의적 행동으로 정보가 유출될 위험이 있습니다.
- **MAC (강제적 접근제어)** — 개인 판단이 아닌 시스템에 미리 정해진 보안 정책에 따라서만 접근 허용. 군대에서 상급자 지시·규정에 따라 기밀을 다루듯, 문서마다 기밀 등급, 사용자마다 보안 등급이 할당됩니다. 벨-라파듈라 모델(1973 년 미 국방부 요청 개발)이 대표적으로, 하위 등급 사용자가 상위 등급 정보를 읽을 수 없게 합니다.
- **RBAC (역할 기반 접근제어)** — 1990 년대부터 널리 사용. 사용자에게 직접 권한을 주는 대신 '역할'이라는 중간 단계를 둡니다. 병원 시스템에서 의사·간호사·원무과·약사 역할을 만들고 각 역할에 필요한 권한을 할당한 뒤 사용자를 역할에 배정. 신입 입사 시 역할만 할당하면 되고 직무 변경 시 역할 교체만 하면 되어 관리가 편하고 정책 일관성 유지가 쉽습니다. 다만 조직이 복잡·세분화되면 역할 수가 기하급수적으로 늘어나는 '역할 폭발' 문제가 생길 수 있습니다.
- **ABAC (속성 기반 접근제어)** — 역할뿐 아니라 시간·위치·접근 방법·네트워크 상태 등 다양한 속성을 종합해 동적으로 권한 결정. 예: '재무팀 역할 + 근무 시간 내 + 회사 네트워크의 보안 단말기'라는 여러 조건을 동시에 만족해야 접근 허용. 프로젝트 진행 상황에 따라 권한이 자동 부여·회수되도록 할 수도 있어 기존 정적 관리와 차원이 다른 유연성을 제공합니다.

사용자 편의성과 특권 관리

- **SSO (단일 접속)** — 한 번의 인증으로 여러 시스템에 자동 로그인. 매일 수십 개 시스템에 각기 다른 비밀번호를 쓰면 기억이 어려워 간단한 비밀번호·재사용으로 보안이 취약해지는데, SSO 는

중앙 인증 서버에서 한 번만 인증받으면 연결된 모든 시스템을 별도 로그인 없이 이용하게 합니다(구글 계정으로 유튜브·지메일·구글 드라이브 사용).

- **PAM (특권 계정 관리)** — 시스템 관리자·DB 관리자 같은 특권 계정은 모든 자원에 접근할 수 있어 악용 시 조직 전체에 치명적입니다. PAM 은 이런 고위험 계정을 별도 분리·관리하고 모든 활동을 상세 기록·감시합니다. 서버 접속 시 사전 승인, 접속 화면 녹화, 접속 시간 제한 후 자동 차단 등으로 특권 남용을 방지합니다.

최소 권한 원칙

모든 접근제어 모델의 기본 원칙입니다. 사용자에게 업무에 꼭 필요한 최소한의 권한만 부여하고 불필요한 권한은 모두 제거해 보안 위험을 최소화합니다(은행 창구 직원에게 조회 권한만 주고 계좌 개설·대출 승인 권한은 주지 않는 것). 또한 업무 분리 원칙을 함께 적용해 한 사람이 전체 프로세스를 독단 처리할 수 없도록 여러 단계로 나눠 견제와 균형을 유지합니다.

> **핵심 요점** 접근제어는 DAC → MAC → RBAC → ABAC로 정교해져 왔으며, 모든 모델을 관통하는 원칙은 '최소 권한'과 '업무 분리'입니다.

16 장. 보안 정책과 거버넌스 체계

정보보안 정책이란 조직이 소유한 정보 자산을 어떻게 보호할지에 대한 기본 원칙과 구체적 실행 방안을 담은 문서입니다. 2017년 한국의 한 대형 병원에서 직원이 개인정보 USB를 무단 반출한 사건은, 명확한 규칙과 감시 체계가 있었다면 예방할 수 있었던 일이었습니다.

정보보안 정책 수립 단계

- **① 정보 자산 파악·분류** — 고객 정보, 재무 데이터, 영업 기밀, 연구개발 자료, 인사 정보 등 핵심 자산을 중요도에 따라 등급을 나눠 분류. 삼성전자 같은 반도체 기업은 차세대 프로세서 설계 도면·공정 기술을 최고 기밀 등급으로 분류해 일반 직원은 접근조차 못하게 합니다.
- **② 위협 분석·우선순위 결정** — 해커 외부 침입, 직원 실수·고의 유출, 천재지변 등 위협 요소별로 발생 가능성과 피해 규모를 평가해 우선순위를 정함(화재보험 가입 시 발생 확률과 예상 피해액을 고려하는 것과 같은 원리).
- **③ 보안 문화 조성** — 아무리 완벽한 정책도 직원이 모르거나 무시하면 의미가 없습니다. 구글·마이크로소프트 같은 기업은 신입 첫날부터 보안 교육을 하고, 정기적으로 가상 피싱 메일을 발송해 직원 반응을 점검합니다.

정보보안 관리체계 — ISMS 와 ISO 27001

- **ISMS** — Information Security Management System(정보보안 관리체계). 자동차 종합 관리처럼 계획 수립·실행·점검·개선의 순환으로 끊임없이 관리. 한국에서는 개인정보보호법에 따라 일정 규모 이상 처리 업체가 ISMS 인증을 의무 취득해야 합니다.
- **ISO 27001** — 국제표준화기구(ISO)의 정보보안 관리시스템 국제 표준. 올림픽에서 모든 참가국이 동일 규칙을 따르듯, 전 세계 기업에 공통 기준을 제공. 삼성·LG·현대자동차 등 한국 대기업도 해외 진출·글로벌 파트너십을 위해 적극 취득하고 있습니다.

정책의 실효성 확보

- **징계 절차** — 위반 시 명확·공정한 징계가 뒤따라야 함. 2018 년 페이스북 케임브리지 애널리티카 개인정보 유출 사건에서 마크 저커버그 CEO 가 미 의회에 출석해 사과하고 직원 징계를 발표. 경고·보안 교육 이수·급여 삭감·정직·해고 등이 위반 정도·의도에 따라 차등 적용됩니다.
- **내부 보안 감사** — 수립된 정책이 현장에서 지켜지는지 정기 점검(교실 청결 검사에 비유). 컴퓨터 보안 설정, 중요 문서 보관, 출입 통제 작동 등을 점검. 2019 년 국내 대형 병원 내부

감사에서 의료진이 환자 정보 USB 를 무단 반출한 사실이 발견되어 회수·재교육이 실시된 사례가 있습니다.

- **정기 보안 교육** — 실제 발생한 사고 사례를 생생하게 소개해 직원들이 보안의 중요성을 체감하게 하는 것이 효과적. 국내 한 금융회사는 정기적으로 가짜 피싱 메일을 발송해 클릭한 직원이 즉시 개별 교육을 받는 실전형 훈련 시스템을 운영합니다.

공급망 보안 관리

현대 기업은 다양한 외부 업체와 협력하는데, 이 과정에서 새로운 보안 위험이 발생합니다. 2013년 미국 타겟의 대규모 유출은 냉난방 시설을 관리하는 외부 업체의 보안이 뚫리면서 수천만 명의 고객 정보 유출로 확산된 사례입니다. 2020년 솔라윈즈 해킹은 네트워크 관리 소프트웨어 업체가 해킹당해 이를 사용하는 전 세계 수천 기업·정부 기관이 동시 피해를 입는 연쇄 반응을 일으켰습니다. 이 때문에 많은 기업이 협력업체 보안 수준을 정기 평가·관리하는 전담 조직을 운영합니다. 보안 협약서에는 최소 보안 기준, 정기 점검 절차, 사고 발생 시 신고 체계, 책임 범위·배상 기준이 명시됩니다.

> **핵심 요점** 보안 거버넌스는 기술 이전에 사람과 조직 문화의 문제입니다. 최고경영진의 확고한 의지·리더십과 전 직원의 참여가 없으면 첨단 기술도 형식적 조치에 그칩니다.

17 장. 위험 분석과 보안 투자 결정

위험 분석과 보안 투자 결정은 보호해야 할 정보 자산이 무엇인지 파악하고, 어떤 위험이 존재하는지 분석한 후, 한정된 예산 안에서 가장 효과적인 대책을 선택하는 과정입니다. 자동차 구입 시 가격·연비·안전성·보험료를 종합해 예산에 맞는 옵션을 고르는 것과 같습니다.

정보 자산의 가치 평가

정보 자산은 하드웨어만이 아니라 고객 개인정보 DB, 영업 기밀, 특허 정보, 직원의 노하우까지 포함합니다.

- **직접적 경제 가치** — 고객 DB 유출 시 법적 배상금, 고객 이탈로 인한 매출 손실, 브랜드 이미지 실추로 인한 장기 피해 등을 모두 계산. 2017 년 에퀴팩스 유출(1 억 4 천만 명)에서 회사는 약 7 억 달러 배상금을 지불했는데, 이는 DB 구축 비용의 수백 배에 달합니다.
- **기밀성·무결성·가용성(CIA)** — 기밀성=외부 노출 시 피해 정도, 무결성=변조 시 영향, 가용성=사용 불가 시 업무 중단 정도. 병원 진료기록은 기밀성·무결성이 매우 중요하고, 온라인 쇼핑몰 상품 정보는 가용성이 특히 중요합니다(서버 다운 시 매분 매출 손실).

위험도 계산

> **핵심 요점** 위험도 = 발생 가능성 × 영향도. 예: 해커 침입 가능성 30%, 침입 시 피해 10억 원 → 연간 예상 손실 3억 원. 모든 위험을 수치화하면 어디에 우선 대응할지 명확히 판단할 수 있습니다.

- **발생 가능성 평가** — 과거 통계(동종 업계 사고 빈도, IT 장비 평균 고장률, 자연재해 주기)를 활용. 방화벽·안티바이러스가 잘 갖춰지면 침입 가능성이 낮아지고, 오래된 OS·지연된 패치는 위험도를 높입니다.
- **영향도 평가** — 직접 피해(시스템 복구비, 데이터 복원비, 법적 배상금)와 간접 피해(업무 중단 매출 손실, 신뢰도 하락, 주가 하락, 경쟁 우위 상실)를 모두 고려. 간접 피해는 장기간 나타나 측정이 어렵지만 직접 피해보다 훨씬 클 수 있습니다.

위험 대응 4 가지 전략

날씨 예보를 듣고 외출 계획을 세우는 것에 비유됩니다.

- **수용(Acceptance)** — 발생 가능성이 낮거나 영향이 미미할 때 그냥 받아들임. 대응 비용이 예상 손실보다 클 때 선택(화분 물주기로 키보드가 젖을 위험은 교체 비용이 작고 빈도가 낮아 수용).

- **완화(Mitigation)** — 가장 일반적. 보안 장비 도입·정책 수립·교육으로 발생 가능성이나 영향도를 줄임(방화벽으로 침입 가능성↓, 백업으로 장애 영향↓). 비용 효과성이 중요 — 100 만 원 손실을 막으려 1000 만 원을 투자하는 것은 비합리적.
- **전가(Transfer)** — 보험 가입·외부 계약으로 위험을 다른 주체에 떠넘김(사이버 보험 가입 시 보험사가 배상, 클라우드 이용 시 서버 관리 책임 전가). 보험료·수수료를 고려해 경제성을 따져야 합니다.
- **회피(Avoidance)** — 위험 요소 자체를 제거(해킹이 걱정되면 인터넷을 안 쓰거나, 유출이 우려되면 개인정보를 수집하지 않음). 가장 확실하지만 비즈니스 기회를 포기해야 하는 경우가 많아 신중해야 합니다.

보안 투자 결정 — ROI

- **ROI 분석** — 투자 대비 수익률. 보안 분야에서는 예방한 손실을 수익으로 계산(1 억 원 투자로 연 3 억 원 피해 방지 시 ROI 200%). 다만 실제로 얼마나 막았는지, 사고가 없었던 것이 시스템 덕분인지 우연인지 판단하기 어려워 정확한 수치화가 쉽지 않습니다.
- **예산 배분 원칙** — 위험도가 높은 영역에 더 많은 예산을 투입하되 비용 효과성을 함께 고려. 보안은 사후 대응보다 사전 예방이 훨씬 경제적입니다(사고 한 번의 피해가 평소 투자 비용의 수십 배).

비즈니스 연속성과 재해 복구

- **비즈니스 연속성 계획(BCP)** — 중대 사고·재해 시에도 핵심 업무를 지속할 수 있도록 미리 준비(화재 대피 경로를 숙지하는 것과 같음). 핵심 업무 식별, 복구 우선순위 결정, 대체 시설 확보, 비상 연락망 구축, 정기 훈련이 포함됩니다.
- **재해 복구 전략(DR)** — 시스템·데이터 손상 시 정상 복원하는 구체적 방법. 복구 시간 목표(RTO)와 복구 지점 목표(RPO)를 미리 설정하고, 실시간 데이터 복제·클러스터링을 활용(온라인 서비스는 1 시간 이내 복구 목표). 정기적으로 테스트해 실제 상황에서 제대로 작동하는지 확인하는 것이 중요합니다.

> **핵심 요점** 위험 분석의 핵심은 '위험도 = 발생 가능성 × 영향도'로 수치화해 우선순위를 정하고, 수용·완화·전가·회피를 비용 효과적으로 조합하는 것입니다. 사후 대응보다 사전 예방이 훨씬 경제적입니다.